JusGov
RESEARCH CENTRE FOR JUSTICE AND GOVERNANCE

JusGov Research Paper Series Paper 2025 - 05

Victor Moreira Mulin Leal

The Data Protection Impact Assessment for the Development and Implementation of a Trustworthy AI: An applied study in the context of small and medium-sized enterprises

fct Fundação para a Ciência e a Tecnologia

Esta publicação é financiada por fundos nacionais através da FCT – Fundação para a Ciência e a Tecnologia, I.P., no âmbito do Financiamento UID/05749/JusGov, Centro de Investigação para Justiça e Governação(JusGov/UM).

About this Research Paper Series

The JusGov Research Paper Series (editor: Andreia Barbosa) provides full articles submitted for publication by our researchers and by visiting researchers as well as speakers at our centre. The content is the responsibility of individual authors. All papers can be accessed from the JusGov Research Paper Series site on Social Science Research Network (SSRN) online platform (https://www.ssrn.com/index.cfm/en/jusgov-res/) and from our official site (https://www.jusgov.uminho.pt/pt-pt/publications/jusgov-research-paper-series/).

About this paper

This paper examines the Data Protection Impact Assessment as an enabling tool for Small and Medium-sized Enterprises to develop and implement Trustworthy Artificial Intelligence systems.

The Data Protection Impact Assessment for the Development and Implementation of a Trustworthy AI: An applied study in the context of small and medium-sized enterprises

Victor Moreira Mulin Leal[1]

Summary: This research examines the Data Protection Impact Assessment (DPIA) as an enabling tool for Small and Medium-sized Enterprises (SMEs) to develop and implement Trustworthy Artificial Intelligence (AI) systems. The study is justified by the need to support these companies in adopting AI-based technologies while maintaining compliance with regulatory and ethical requirements, contributing academically to the integration between the General Data Protection Regulation (GDPR) and the ethical principles of respect for human autonomy, prevention of harm, fairness, and explainability, all established by the European Commission. This article is based on a systematic documentary analysis, examining scientific articles, normative instruments, and guidelines from Data Protection Authorities within the European scenario. The results demonstrate the viability of DPIA as a precursor instrument for the development and implementation of Trustworthy AI systems, evidenced by the convergence between the GDPR and European ethics guidelines, identifying significant operational synergies. The DPIA methodology proposed in this article offers a framework for implementing technical and legal safeguards without compromising innovation, although there are structural limitations in the regulatory framework. The limitations identified indicate the need for future studies on the possibility of integrating DPIA with the requirements of the AI Act, in order to continually improve the proposed framework.

Keywords: Data Protection; Artificial Intelligence; Impact Assessment; Small and Medium-sized Enterprises; Ethical principles.

[1] PhD candidate in Public Legal Sciences at the University of Minho, Portugal, with a fellowship from the Portuguese Foundation for Science and Technology (FCT) under the RENATES project (nº 101721692). Master in Law & Informatics.

Introduction

The advancement of artificial intelligence (AI) has driven a significant transformation in the business landscape, and small and medium-sized enterprises (SMEs) are progressively adopting these technologies to remain competitive. However, this digitalization process presents substantial challenges related to regulatory compliance and the implementation of ethical practices in the development and implementation of algorithmic systems. In this context, the General Data Protection Regulation (GDPR) has emerged as an important regulatory framework, establishing specific requirements for the processing of personal data, including those processed by AI systems.

The complexity of this scenario intensifies when we consider the ethics guidelines established by the AI High Level Expert Group (AI HLEG, 2019), which defines specific criteria for the development of Trustworthy AI. These guidelines state that algorithmic systems must be both legal, ethical, and technically robust, presenting compliance streams that often challenge the operational and financial capacity of SMEs. Therefore, the intersection between data protection and ethical AI principles requires methodological tools to enable their implementation in the specific context of these organisations.

From this perspective, the Data Protection Impact Assessment (DPIA), provided for in Article 35 of the GDPR, is a potential facilitating tool for SMEs to develop and implement Trustworthy AI systems. As Hijmans and Raab (2018) point out, there is an intrinsic relationship between the GDPR and fundamental ethical dimensions, manifested through values such as human dignity and personal autonomy. This feature suggests that the DPIA, suitably adapted, can serve as an initial methodological framework for implementing Trustworthy AI requirements.

Given this, this paper investigates the extent to which DPIA can act as a facilitating instrument for SMEs to develop and implement Trustworthy AI systems. This question has significant social relevance considering the fundamental role of SMEs in the European economy and the need to support them in the regulatory context related to AI. From an academic point of view, the research contributes to filling a gap in the legal literature by proposing the integration of data protection regulatory requirements and ethical principles of Trustworthy AI.

In the end, a methodology will be proposed for SMEs to carry out DPIA in the context of AI systems, integrating data protection requirements and ethical principles established by the European Commission. To achieve this result, three stages will be developed: (i) analysis of the ethical principles and requirements of Trustworthy AI established by the European Commission; (ii) identification of the fundamental elements of DPIA established by Article 35 of the GDPR and by applicable guidelines; and (iii) structure of specific modules for conducting the proposed DPIA methodology, which are inspired by the guidelines of the Article 29 Working Party (WP29, 2017) and the Information Commissioner's Office (ICO, 2018, 2020), adapted to the particularities of SMEs and the specific requirements of AI systems.

Finally, it is worth noting that, despite the recent approval of the AI Act by the European Union, which establishes a specific regulatory framework that includes impact assessment requirements for AI systems classified as high risk, this work focusses on instrumentalising the DPIA as an initial and methodologically accessible mechanism for SMEs to develop and implement Trustworthy AI systems. This methodological option is based on three predominant aspects: (i) the establishment of the GDPR in the European legal system and the consequent familiarity of organisations with its instruments and basic principles; (ii) the existence of a robust body of interpretative guidelines issued by the Data Protection Authorities on the operationalisation of DPIA; and (iii) the possibility of taking advantage of organisational structures and processes already implemented in compliance with the GDPR, optimising resources and promoting operational efficiency in the specific context of SMEs.

1. Trustworthy Artificial Intelligence, in line with the European Commission's Guidelines

AI-based systems and applications are significantly transforming contemporary legal, social, and economic relations, which calls for a regulatory framework that harmonises technological development with the protection of fundamental rights.

In this context, the European Commission, recognising the need to establish clear and ethically orientated normative parameters, has presented specific guidelines for the development of Trustworthy AI systems, in which

it establishes ethical principles and objective requirements to safeguard fundamental values such as human dignity, individual autonomy, safety, and fairness.

1.1 The Concept of a Trustworthy AI: Legal, Ethical, and Technical Components

The publication of the Ethics Guidelines for Trustworthy AI (Ethics Guidelines) by AI HLEG 8 April 2019 was a significant milestone for the development and implementation of algorithmic systems within the European Union (AI HLEG, 2019). This document inaugurated a regulatory perspective based on the integration of fundamental rights and ethical principles that should guide technological innovations.

The Ethics Guidelines consolidated a breakthrough in the systematisation of the normative framework for AI, based on the Charter of Fundamental Rights of the European Union and universal human rights (AI HLEG, 2019). This structure demonstrated the need to harmonise technological progress with the values of European society, establishing objective criteria to safeguard individual and collective rights in the context of digital transformation.

The central purpose of the guidelines is to provide guidance for the development of AI-based systems that can be considered trustworthy (AI HLEG, 2019). This approach recognises that trustworthiness transcends technical efficiency, incorporating ethical, legal, and social aspects that must be observed throughout the system's lifecycle. Consequently, the guidelines establish a structured path for developers and organisations to implement AI-based technologies in accordance with ethical principles and fundamental rights, promoting a human-centred and socially responsible technological evolution (AI HLEG, 2019).

In this context, the Ethics Guidelines present a systematic structure that enables a gradual understanding of the elements necessary for the responsible development of algorithmic systems. Chapter I establishes the fundamental rights and ethical principles that must be observed when developing trustworthy AI applications (AI HLEG, 2019). This initial structure presents the premises that guide all subsequent development of the document.

Chapter II materialises the application of these fundamentals by establishing seven essential requirements for the development of trustworthy AI-based systems (AI HLEG, 2019). This section transposes general principles into specific guidelines, providing objective parameters for the implementation of ethical precepts in the development process. Furthermore, Chapter III presents the mechanisms for operationalising these requirements, providing practical tools for their effective implementation (AI HLEG, 2019).

As you can see, the document goes beyond a simple list of ethical principles and is an instrument that integrates theory and practice in the development of AI-based technologies (AI HLEG, 2019). This approach recognises the complexity inherent in the process and offers comprehensive guidelines ranging from conceptual foundations to their respective application. The progressive framework allows organisations and developers to understand the building blocks of trustworthy AI and the mechanisms for its effective implementation.

The construction of a trustworthy AI is based on three components that must be developed in an integrated and harmonious manner. As established by AI HLEG (2019), the algorithmic system must meet three fundamental dimensions: be "Legal", observing the applicable set of regulations; "Ethical", ensuring compliance with fundamental values and principles; and "Solid", ensuring technical and social consistency. These three pillars form the essential core for the development of AI applications that meet contemporary legal and social requirements.

It is important to note that the implementation of AI-based systems requires a comprehensive approach that covers all phases of the system's life cycle (AI HLEG, 2019). Developers and organisations must constantly evaluate and monitor the established criteria, from initial conception to final implementation. This perspective shows that compliance is not restricted to a specific moment but is a continuous process of verification and adaptation to the guidelines. The agents responsible for development must incorporate evaluation mechanisms to ensure that standards are maintained at each stage of the process.

However, mere legal compliance is not enough to characterise an algorithmic system as trustworthy (AI HLEG, 2019). This finding highlights the multifaceted nature of reliability in AI applications, where legal, ethical and technical aspects are inextricably linked. The interaction between these components structures a framework that requires integrated analysis, recognising that each element, although necessary, is not sufficient in isolation to ensure effective system compliance.

Given the complex scenario surrounding algorithmic systems and the pressing need to safeguard fundamental rights in the context of digital transformation, the ethical dimension emerges as a core element in building trustworthy AI. Therefore, it is imperative to deepen the analysis of the ethical principles established by AI HLEG (2019), considering that they constitute the foundation for the development of AI systems that promote a balance between innovation and protection of rights. A systematic understanding of these principles helps organisations, especially SMEs, to implement algorithmic systems responsibly and in line with society's fundamental values.

1.2 The ethical principles of a trustworthy AI

The Ethics Guidelines present four essential principles for the development of a Trustworthy AI: respect for human autonomy, prevention of harm, fairness, and explainability (AI HLEG, 2019). These ethical imperatives are based on Article 2 of the Treaty on the European Union.

These principles, even without binding force, are important in interpreting how fundamental rights should be protected in the face of new technologies. It is important to note that no principle is more important than another, and they may even conflict depending on the situation. In such cases, each case needs to be analysed individually to find the best solution (AI HLEG, 2019).

1.2.1 Principle of respect for human autonomy

The principle of respect for human autonomy is a core element in the architecture of technologies based on trustworthy AI, founded on the essential rights to individual dignity and freedom. This concept is based both on the constitutional protection of fundamental rights and on the very structure of the Democratic Rule of Law, which presupposes individual autonomy as a legitimising element of social or technological legal relations. From this perspective, Floridi et al. (2019) establish as a central premise the right to self-determination of individuals over the algorithmic treatments to which they are subject.

Realising this principle in AI applications requires a specific methodology, as established by AI HLEG (2019), prioritising the development of systems that leverage human competencies. This approach emphasises strengthening users' cognitive and sociocultural capabilities. Floridi et al. (2019) introduce a complementary dimension by proposing that, in addition to promoting human autonomy, limitations be placed on machine autonomy, guaranteeing reversibility mechanisms when necessary.

The materialisation of the principle of human autonomy in AI technologies requires integrated legal and technical mechanisms. From this perspective, they become instruments that ensure access to information and the exercise of decision-making power over algorithmic delegations. The concept of meta-autonomy, according to Floridi et al. (2019), underpins this construction by determining that the preservation of human decision-making power is an essential element, guaranteeing both the exercise of freedom of choice and the prerogative of revocation.

1.2.2 The principle of damage prevention

The principle of preventing harm in AI technologies is based on a double normative matrix: respect for human dignity, as established in Article 2 of the Treaty on the European Union (TEU), and the protection of the physical and mental integrity of individuals, provided for in Article 3 of the Charter of Fundamental Rights of the European Union (Charter). This legal framework includes a comprehensive conceptual dimension which, according to AI HLEG (2019), incorporates both individual and collective aspects of potential harm, including intangible impacts on social, cultural, and political environments. The systematic classification proposed by Floridi et al. (2019) establishes a fundamental distinction between accidental harm, resulting from the excessive use of AI applications, and deliberate harm, resulting from the misuse of these systems.

Operationalisation of the damage prevention principle requires the implementation of specific technical and legal safeguards in algorithmic solutions. This preventive perspective, as established by Floridi et al. (2019), prioritises the mitigation of damage regardless of its origin, whether derived from human intentionality or the unforeseen behaviour of systems. The AI HLEG (2019) complements this approach by establishing objective technical requirements that determine the need to incorporate security mechanisms against malicious use, consolidating a comprehensive protective framework in the development and implementation of AI-based technologies.

1.2.3 The Principle of Fairness

The principle of fairness in AI systems is based on respect for human dignity and the fundamental right to equality, as set out in Article 2 of the TEU. This normative basis is consolidated through a double dimension: substantive and procedural. From the substantive perspective, as AI HLEG (2019) points out, AI applications must ensure fair and equitable services, establishing safeguards against unfair bias and discriminatory practices that can stigmatise specific individuals or groups.

The procedural dimension of the principle of fairness finds significant support in the GDPR, especially in Article 22(3), which establishes specific guarantees for automated individual decisions. This procedural aspect is intrinsically related to the principle of proportionality, according to which, as established by the AI HLEG (2019), when faced with multiple alternatives to achieve a given objective, priority must be given to the one that least interferes with fundamental rights and established ethical standards.

AI-based technologies, by implementing the principle of fairness, indirectly promote users' individual freedom. This correlation manifests itself to the extent that discriminatory or inequitable treatments directly impact the autonomy of individuals. Thus, algorithmic solutions must incorporate technical and procedural safeguards that ensure not only formal compliance with the precepts of fairness but also their effective materialisation in the development and implementation of these technologies.

1.2.4 The principle of explainability

The principle of explainability establishes direct links with fundamental principles of the legal system, such as human dignity, individual freedom, and justice (AI HLEG, 2019), operating as an instrument to verify fairness in algorithmic systems. This interconnection of principles strengthens the right to information as an essential component of individual autonomy, allowing subjects to understand and question the decisions that affect them. Thus, the transparency provided by explainability transcends mere technical compliance, becoming a fundamental guarantee in legal and social relations mediated by AI-based technologies.

This principle is a core element for building and maintaining user trust in AI systems, as established by AI HLEG (2019). This systemic dimension is consolidated as a transversal principle which, according to Floridi et al. (2019), complements and strengthens all the other ethical principles applicable to AI-based technologies. Explainability manifests itself through a comprehensive informational dimension, which includes not only the transparency of algorithmic processes, but also clarity about the purposes and components of the system, especially for individuals directly or indirectly affected by its decisions.

The application of the explainability principle has gradations proportional to the potential impact of automated decisions. While music content recommendation systems require a lower degree of transparency, AI applications in the medical field, which influence diagnoses and treatments, require higher levels of explainability. This gradation highlights the contextual nature of the principle, which adapts to the criticality and sensitivity of different technological applications, safeguarding fundamental rights in proportion to the risks involved.

1.3 The Seven Essential Requirements for Implementing a Trustworthy AI

In synergy with the ethical principles analysed in the previous topic, and in order to make them more operational and concrete in the implementation of AI systems, it is necessary to examine the seven requirements that instrumentalise these precepts. These requirements, presented in a non-hierarchical structure, comprise: (i) human action and supervision; (ii) technical soundness and safety; (iii) data privacy and governance; (iv) transparency; (v) diversity, non-discrimination, and equity; (vi) societal and environmental well-being; and (vii) accountability.

1.3.1 Human action and supervision

The implementation of human action and supervision mechanisms in AI systems is supported by essential legal principles, including respect for human dignity, individual freedom, and autonomy. As AI HLEG (2019) points out, this requirement emerges from the need to safeguard individual self-determination as a structuring element of the normative architecture of algorithmic systems. This perspective is in line with the paradigm of human centrality,

which is a fundamental principle for the development of a technologically and ethically advanced society (European Commission, 2019).

The operationalisation of these principles is materialised through specific protection and risk assessment mechanisms. In this sense, AI HLEG (2019) establishes the imperative need to carry out impact assessments on fundamental rights when AI applications have the potential to negatively affect individuals or society. This preventive approach is complemented by a multilevel control structure that must permeate all stages of algorithmic processing, guaranteeing adequate degrees of supervision, adaptability, and explainability of the systems.

The implementation of human supervision mechanisms in AI systems must meet concrete and measurable objectives. As established by AI HLEG (2019), these technologies need to function as instruments for democratic empowerment and equitable social development, always preserving and promoting fundamental rights of individuals. This perspective emphasises the need for algorithmic systems to act as facilitators of the human decision-making process, allowing for more informed choices aligned with individual interests, without compromising users' autonomy (European Commission, 2019).

To achieve these goals, it is essential to develop a governance model that harmonises technical aspects and ethical legal considerations in the supervision of AI systems (AI HLEG, 2019). This approach proves particularly important in the context of SMEs, which need clear guidelines to implement human supervision mechanisms without hindering their ability to innovate. The balance between control and technological development allows companies to adopt AI-based solutions that simultaneously respect fundamental values and promote responsible technological advances, thus ensuring the reliability and effectiveness of these systems in the business environment.

1.3.2 Technical soundness and safety

Technical soundness and safety in AI applications is based on the right to respect physical and mental integrity, as set out in Article 3 of the Charter, and on the ethical principle of preventing harm. The AI HLEG (2019) establishes four essential characteristics to meet this requirement: resilience against attacks, contingency planning, accuracy, and reliability with reproducibility. This preventive approach aims to ensure that AI systems work as intended, minimising risks, and avoiding unacceptable harm in their operation.

Protection against vulnerabilities is a central element in the architecture of AI systems. Attacks targeting the structure, data, or models can compromise their functioning, generating instability, and inaccurate decisions. For this reason, algorithmic solutions must incorporate security and protection principles by design, implementing processes to minimise or reverse unintended consequences (European Commission 2019).

Accuracy and reliability represent fundamental pillars for algorithmic systems, especially when they directly impact individuals. The AI HLEG (2019) states that reliability manifests itself when the system operates properly with different input data, while reproducibility ensures consistent behaviour under identical conditions. The level of accuracy must be proportional to the potential impact on human lives, since incorrect interpretations can result in unfair decisions, affecting individuals' fundamental rights.

1.3.3 Privacy and data governance

Privacy and data governance are emerging as fundamental elements in the development of AI systems, based on the right to data protection and the ethical imperative to prevent harm. This aspect gains even more relevance considering that the damage caused can be immaterial in nature, as threats to privacy increase when the individual is inserted in the context of a surveillance-based economy. As highlighted by AI HLEG (2019), modern AI applications are capable of inferring a wide range of sensitive information about individuals, including personal preferences, demographic characteristics, and even political and religious beliefs.

To establish a solid foundation of protection, algorithmic solutions must incorporate fundamental principles established by the GDPR in Article 5(2). This implies ensuring data processing that is lawful, fair, and transparent, for a specified purpose and limited to what is necessary. According to the AI HLEG guidance (2019), this adequacy must be demonstrated by implementing the concepts of data protection by design and by default throughout the system's life cycle.

Data quality and integrity are also crucial aspects in the governance of AI systems. The use of inaccurate, incorrect, or biased data can result in discriminatory decisions, compromising the fairness and equity of the system. In this context, organisations that process personal data need to implement robust protection measures, preventing unauthorised access and potential leaks that could compromise individuals' privacy.

1.3.4 Transparency

Transparency, as a fundamental requirement for trustworthy AI applications, establishes a direct relationship with the ethical principle of explainability and is structured around three essential characteristics: traceability, communication, and explainability itself (AI HLEG, 2019). This tripartite structure underpins not only the mechanisms needed to ensure that AI-based technologies operate within verifiable parameters but also establishes guidelines for transparent interaction with their users, expressly prohibiting these systems from presenting themselves as human beings, a practice that would constitute attempted confusion or deception (AI HLEG, 2019).

At the operational level, traceability emerges as a crucial element, as it makes it possible to systematically record and document both the decision-making process and the decisions taken by the algorithmic solutions themselves (European Commission 2019). This feature materialises as an auditability tool, making it possible to identify and understand any flaws in the decision-making process. Systematic documentation of processes not only enables the technical verification of systems, but also ensures the ability to explain the technical aspects and human decisions that permeate the entire process (AI HLEG, 2019), establishing concrete mechanisms to prevent algorithmic opacity.

The dimension of explainability takes on particular relevance in the organisational context, manifesting itself through transparency regarding the degree of influence that AI-based technologies exert on institutional decision-making processes (AI HLEG, 2019). This perspective intensifies especially when algorithmic systems generate significant impacts on the individual sphere, a circumstance in which it becomes imperative to be able to request adequate clarification on the decision-making process employed (AI HLEG, 2019). This approach aims to ensure both the effectiveness of corporate governance and the exercise of fundamental rights, especially access to justice, which could be undermined by the opacity of automated decision-making systems.

1.3.5. Diversity, Non-Discrimination and Equity

Diversity, nondiscrimination, and fairness are fundamental requirements that flow from the principle of equity and are directly linked to human dignity. This requirement is established as an indispensable condition throughout the life cycle of AI-based technologies and is essential for the realisation of Trustworthy AI (AI HLEG, 2019).

In this context, understanding data as a portrait of society (Cortiz, 2019) reveals significant structural challenges. Data sets, often affected by historical deviations and structural discriminatory conduct, can result in unfairly discriminatory and prejudiced decisions against minorities and vulnerable groups when used in algorithmic systems. This reality requires specific attention in the context of SMEs.

To address these challenges, it is necessary to eliminate identifiable biases as early as the data collection phase (AI HLEG, 2019), through consistent governance and supervision processes. The formation of teams with different backgrounds, cultures, and disciplines strengthens this objective, enhancing the ability to ensure nondiscrimination and fairness in the development of AI applications (AI HLEG, 2019).

1.3.6 Societal and environmental well-being.

In line with the principles of fairness and harm prevention, societal and environmental well-being is a fundamental requirement that represents a broad concern for society, sentient beings, and the environment, where everyone must be considered as a stakeholder throughout the AI life cycle (AI HLEG, 2019). This perspective establishes that, for an AI-based technology to be considered trustworthy, it is necessary to consider its impact on the environment and sentient beings (European Commission 2019). This approach bases the development of algorithmic systems on the principles of sustainability and social and ecological responsibility.

As part of the requirement for societal and environmental well-being, AI-based technologies must incorporate sustainability criteria and respect for the environment in their design. This guideline materialises through development, deployment, and use processes that prioritise less harmful choices in terms of energy consumption (AI HLEG, 2019). At the same time, AI applications must include systematic assessments of the impacts of their use on users' social, physical, and mental skills, recognising their intrinsic social dimension (AI HLEG, 2019).

This requirement also establishes fundamental links with respect for democracy, justice, and the rule of law, demanding a comprehensive analysis of the impacts of AI-based technologies from a societal perspective (AI HLEG, 2019). In this context, it becomes imperative to systematically assess the effects of these algorithmic solutions on democratic institutions and society in general, with special attention to democratic processes, ensuring that technological development strengthens the fundamental structures of the rule of law.

1.3.7 Accountability

Accountability, as one of the seven essential requirements outlined in the Ethics Guidelines, plays a key role in promoting ethical principles and robust governance practices. This requirement is intrinsically linked to fairness, requiring the implementation of mechanisms that ensure both effective responsibility and accountability for the consequences of algorithmic solutions (European Commission 2019). The materialisation of accountability requires the incorporation of elements such as auditability, mitigation, and communication of adverse impacts, compromise solutions, and accessible remedies (AI HLEG, 2019). These components are fundamental to consolidating trust in AI applications, as well as to strengthening the relationship with users and other stakeholders.

As part of the instruments that enable accountability, auditability, and impact assessments occupy a prominent position. Auditability enables the detailed analysis of algorithms, data, and decision-making processes, and the publication of audit reports contributes directly to increasing transparency and trust (AI HLEG, 2019). On the other hand, impact assessments play a strategic role in identifying and mitigating risks, especially in solutions based on personal data, as established by Article 35 of the GDPR. These tools not only document the practices adopted in the development of algorithmic systems but also support the adoption of corrective and preventive measures to ensure ethical and regulatory compliance.

Adopting the accountability requirement presents a relevant opportunity for SMEs by facilitating the implementation of solutions aligned with ethical and regulatory standards. Instruments such as impact assessments and independent audits can be tailored to the specific needs of these organisations, promoting competitive and responsible development (AI HLEG, 2019). By incorporating these mechanisms, SMEs increase their credibility with the market and stakeholders, as well as ensuring that regulatory and social expectations are met, strengthening trust in their technological solutions.

1.4 Challenges faced by SMEs to ensure the development of Trustworthy AI systems

SMEs face a number of complex challenges when seeking to develop and implement AI systems that meet the trust criteria set by the European Union.

According to Oldemeyer et al. (2024) and Yusuf et al. (2024), the lack of adequate technological infrastructure represents an initial barrier, since these companies rarely have the computing power needed to operate AI systems. The authors also point out that access to and management of high-quality data is a central obstacle, as SMEs often lack the resources to access or maintain robust data sets. Crockett et al. (2023) and Iyelolu et al. (2024) also point out that the shortage of qualified professionals in these organisations compromises both the development and proper management of these systems, creating a technical gap that is difficult to overcome.

The economic scenario presents equally significant challenges for SMEs in the context of trustworthy AI. Oldemeyer et al. (2024), Yusuf et al. (2024) and Iyelolu et al. (2024) show that the high costs associated with implementing AI systems, including investments in software, hardware, and specialised personnel, often exceed the budgetary capacities of these companies. Li et al. (2023) and Polemi et al. (2024) point out that this scenario becomes even more complex when considering the development of Trustworthy AI, which requires additional investments to guarantee aspects such as transparency, fairness, and privacy, elements that considerably increase the total cost of the project.

The ethical and social dimension of the development of trustworthy AI represents another challenge for SMEs. Crockett et al. (2023) and Polemi et al. (2024) note that these companies often have limitations in understanding and implementing the ethical implications of AI, especially on issues of algorithmic bias and data privacy. Li et al. (2023) emphasise that this scenario is compounded by the difficulty SMEs have in establishing public trust in their AI solutions, mainly due to their restricted ability to implement and demonstrate robust ethical practices in the development of their systems.

On the regulatory front, SMEs encounter additional challenges in implementing Trustworthy AI. Yusuf et al. (2024) and Iyelolu et al. (2024) identify that navigating the complex regulatory environment, especially regarding data protection laws and AI-specific regulations, presents an obstacle for companies with limited legal resources. Crockett et al. (2023) and Polemi et al. (2024) complement this analysis by pointing out that the lack of standardised guidelines hinders the consistent implementation of good practices. In this context, Carayannis et al. (2023) suggest that these obstacles can be overcome through strategic support and appropriate compliance management tools. In light of this, the Data Protection Impact Assessment emerges as a promising instrument to help SMEs seek compliance with regulatory and ethical requirements in the development of Trustworthy AI systems.

2. The General Data Protection Regulation and its Impact Assessment

The GDPR serves as an important normative instrument in the regulation of AI systems, establishing specific parameters for the processing of personal data in the European context. Its relevance to the development of a Trustworthy AI is manifested through principles and obligations that dialogue directly with the requirements established for a Trustworthy AI.

This chapter analyses the intersection between the GDPR and the development of AI systems, exploring how some of its provisions can contribute to the implementation of algorithmic technologies that respect both the privacy and fundamental rights of data subjects, in line with the ethical principles of Trustworthy AI.

2.1 How the GDPR can help in the development of a Trustworthy AI

The relationship between AI and the GDPR is established primarily through the very operational nature of algorithmic systems, especially those that rely on the processing of personal data, an activity regulated by Article 4(2) of the GDPR. This connection is strengthened through the GDPR's material scope of application (Art. 3(1)), which provides a clear framework for regulating the data collection, processing, and sharing practices that underpin algorithmic solutions. As studies in the field point out, this legal foundation provides a solid basis for the GDPR to effectively regulate AI systems that process personal data.

Furthermore, the GDPR goes beyond its regulatory function by incorporating a substantial ethical dimension into its structure, aligning directly with the objectives of a Trustworthy AI. As Hijmans and Raab (2018, 6) point out, there is a close relationship between the GDPR and ethics, manifested through fundamental moral values such as human dignity and personal autonomy. This ethical dimension is embodied in the basic principles of the regulation, especially in Article 5(1)(a), which establishes the values of lawfulness, fairness, and transparency as the guiding principles for data processing. Recital 4 of the GDPR reinforces this approach by stating that the processing of personal data should be designed to serve people, thus establishing a human-centered perspective for the development of AI systems.

AI systems present specific risks that the GDPR is structurally prepared to address. Among the most critical concerns are the unlawful intrusion of privacy, the unfair processing of personal data, and the use of biased data that can result in unjustified discrimination. The GDPR demonstrates awareness of these risks, as evidenced in Recital 75, which expresses concern about the seriousness of the impacts on the rights and freedoms of natural persons. Furthermore, the GDPR incorporates values relating to human autonomy, individual freedom, fairness, and transparency, as highlighted in Recitals (71) and (85), thus offering a robust framework for addressing ethical concerns relating to the development and implementation of AI systems.

The suitability of the GDPR as an instrument to promote the development of Trustworthy AI is based on both its legal legitimacy and its ethical scope. While some academics, such as Evas (2019, 6), advocate a strictly legal interpretation of the regulation, other scholars, such as Hijmans and Raab (2018, 6), propose a broader reading that

recognises the incorporation of ethical values and fundamental principles. This latter perspective highlights how the GDPR can significantly contribute to the ethical component in the development of AI systems. By combining rigour in the processing of personal data with fundamental ethical principles, the GDPR offers valuable guidelines for the development of AI systems that respect both the privacy and dignity of the individuals whose data are processed.

2.2. The principle of responsibility and the need to demonstrate compliance in Data Processing: The foundations for the development of Trustworthy AI

In the context of the GDPR, the principle of responsibility emerges as one of the pillars for the processing of personal data. Based on Article 5(2), this principle presents a double obligation on the controller. On the one hand, strict compliance with the principles relating to the processing of personal data is required and, on the other, the duty to prove such compliance is imposed (Cordeiro 2020, 162; Kuner and Bygrave 2020, 319). This dual dimension is not just a regulatory formality, but a real mechanism for the effectiveness of the GDPR, since the duty to demonstrate compliance is treated as an independent obligation, the breach of which can result in specific liability. The Article 29 Working Party emphasises that the purpose of this provision is to strengthen the responsibility of controllers in the processing of personal data, without prejudice to concrete accountability measures that may complement this principle (WP29, 2010).

The operationalisation of the principle of responsibility in the GDPR is manifested through various instruments and specific obligations. Article 24(1) of the GDPR establishes, as one of these manifestations, the implementation of technical and organisational measures that must take into account "the nature, scope, context, and purposes of the data processing, as well as the risks to the rights and freedoms of natural persons". Cordeiro (2020, 321) emphasises that these measures must be interpreted broadly, covering all aspects that can influence compliance with the GDPR or affect the rights of data subjects. In addition to these measures, the GDPR provides for other important operational mechanisms, such as records of processing activities (Article 30), notification of data breaches (Article 33), and, notably, the DPIA (Article 35), which is one of the main instruments for enforcing the principle of accountability, especially in contexts of high-risk processing, such as AI-based systems.

The effective implementation of the principle of responsibility is intrinsically linked to a risk-based approach, which differs from the traditional rights-based approach. This preventive perspective is a requirement that stems from the fundamental right to the protection of personal data and has significantly influenced the development of the GDPR (Cordeiro 2020). In practice, this means that even before starting any project or initiative, the data controller must assess the risks, impacts, and possible consequences that the processing of data could have on the data subjects. This preliminary analysis is not a mere formality: it is what allows the controller to be truly able to apply the appropriate measures in the specific case, whether they are technical, organisational, or, when necessary, carrying out a DPIA. The GDPR requires this preventive approach precisely because it recognises that the effective protection of personal data cannot depend solely on reactive measures but must be anchored in an organisational culture of prevention and continuous risk management.

The application of the risk-based approach takes on specific contours in the environment of AI systems, simultaneously laying the foundations for regulatory compliance and the development of Trustworthy AI. The GDPR recognises the particularities of this technological context by requiring a differentiated assessment for automated data processing, based on the inherent complexity of these technologies and their potential to generate significant impacts on the rights and freedoms of data subjects.

The unique characteristics of AI systems - such as the ability to process large volumes of data, identify patterns, and make automated decisions - demand a multifaceted analysis that considers both technical and organisational aspects. Therefore, this analysis, when structured through the principle of responsibility, converges with the requirements of a Trustworthy AI, establishing a standard of governance that favours transparency and accountability.

In this context, DPIA emerges as a central instrument, not only for the GDPR compliance, but as a tool for organisations to implement and demonstrate ethical practices in AI development, thus creating an operational bridge between data protection requirements and the principles of Trustworthy AI.

2.3 The Data Protection Impact Assessment: Analysis of Article 35 of the GDPR

The DPIA, established by Article 35 of the GDPR, is a fundamental instrument for protecting the rights and freedoms of personal data subjects. According to the WP29 guidelines (2017), the DPIA should be understood as a "living and continuous document", which requires constant updating throughout the data processing cycle. This dynamic characteristic manifests itself in three distinct and complementary phases: project initiation, development, and execution, guaranteeing a complete assessment that is adaptable to changes in processing activities.

Updating the DPIA becomes especially relevant in contexts where data processing is dynamic and subject to permanent changes, as highlighted by the WP29 (2017). This approach is reinforced by Article 35(11) of the GDPR, which establishes the possibility for the controller to carry out periodic checks to verify that the processing complies with the assessment initially carried out. As evidenced by the Information Commissioner's Office (ICO, 2018), the conduct of DPIA should be geared toward minimising and determining acceptable levels of risk in the specific circumstances of each processing, thus establishing a continuous process of evaluation and adequacy.

To operationalise this dynamic data protection instrument, the GDPR establishes a clear structure of responsibilities and participation. According to Article 35(2) of the GDPR, the DPIA must be performed by the controller, who can choose to conduct the assessment internally or use experts outside the organisation. This flexibility in execution is complemented by the possibility of consulting the Data Protection Officer (DPO), when appointed, which results in an additional layer of expertise to the process.

A particularly relevant aspect of this participatory structure is found in Article 35(9) of the GDPR, which provides for the possibility of consulting data subjects or their representatives about the planned processing. This provision significantly strengthens informational self-determination, allowing data subjects to express their opinion on the form and consequences of the processing of their own data. It is important to note that, according to the WP29 (2017) guidelines, if the controller chooses not to consult the data subjects, they must formally justify the reasons for this decision, thus guaranteeing the transparency of the decision-making process.

Based on the structure of responsibilities established, the GDPR defines in Article 35(7) the essential requirements that must be met when draughting a DPIA. This methodology is structured in four elements: first, a systematic description of the processing operations envisaged, including purposes and legitimate interests; second, an assessment of the necessity and proportionality of the operations in relation to the objectives established; third, an assessment of the risks to the rights and freedoms of data subjects; and fourth, the measures envisaged to address these risks, including guarantees and security procedures.

As clarified by the ICO (2018), although the responsible party does not have the duty to completely eliminate risks, the conduct of the DPIA should seek to minimise them to acceptable levels in the specific circumstances. An important methodological aspect, highlighted by WP29 (2017), is that the entire assessment should be carried out from the perspective of the data subject, not the organisation, thus reinforcing the commitment to effective protection of fundamental rights. This methodological approach allows the controller to have the necessary flexibility to deepen the analysis according to the specifics of each case, always keeping the focus on protecting the rights of the data subjects.

Once the methodology described has been applied, if the person responsible for processing identifies that the measures planned to mitigate the risks are inadequate or insufficient, the situation of residual risks is configured. As WP29 (2017, 22) clarifies, these risks are characterised when (i) they do not exist, (ii) they are not known, or (iii) the appropriate measures have not been properly applied in view of the high risks identified in the DPIA. In these situations, Article 36(1) of the GDPR establishes the obligation to consult the supervisory authority before starting processing.

The prior consultation process gives the supervisory authority significant powers under Article 58 of the GDPR, ranging from issuing written guidelines to imposing more severe measures. These include the possibility of ordering the controller to implement specific measures to comply with the provisions of the GDPR (Article 58(2)(d)) or, in more serious cases, imposing a temporary or definitive limitation on processing, or even prohibiting it (Article 58(2)(f)). This administrative oversight mechanism ensures that, regardless of the solution adopted, whether adequacy or cessation of processing, the rights and interests of data subjects remain protected.

The effectiveness of the assessment and prior consultation process is intrinsically linked to the transparency aspects of the DPIA. Although WP29 (2017) encourages the publication of a summary or conclusions of the assess-

ment, the GDPR does not establish a legal obligation to publish this document. The WP29 guidance recognises that there is no need for full disclosure of the DPIA, especially when this could compromise trade secrets or sensitive commercial information, alternatively suggesting the publication of a summary of the main conclusions.

It is important to note that the publication, even partial, can help build trust in treatment operations and demonstrate accountability and transparency. Furthermore, as several authors have pointed out (Malgieri and Kaminski 2019; Kloza et al. 2019; Veale, Binns, and Ausloos 2018), the lack of mandatory publication is one of the main limitations of this instrument. It is worth noting that the active information duties provided for in Articles 13 and 14 of the GDPR can be partially satisfied through the publication of the DPIA, especially with regard to the systematic description of the processing operations and their purposes, thus contributing to greater transparency of the process.

The issue of transparency becomes even more relevant when considering DPIA as a facilitating tool for the development of Trustworthy AI systems, especially in the context of SMEs. The relevance of this approach is particularly evident in Articles 13(2)(f) and 14(2) of the GDPR, which require the presentation of useful information on the logic of the automated processing, including the importance and the expected consequences of this processing for the data subject.

Finally, it is worth noting that the DPIA, by acting as a risk management and assessment tool, responds simultaneously to the dual approach of the GDPR: the risk-based approach and the substantive protection of rights. This feature makes it particularly suitable for operationalising the initial requirements of a Trustworthy AI, as it allows the system's impacts on the rights and freedoms of individuals to be systematically assessed and documented, always keeping the perspective of the data subject at the heart of the analysis. Thus, although there are specific instruments in the AI Act that will be the subject of analysis in a future article, the GDPR's DPIA represents a concrete and accessible initial step for SMEs towards the operationalisation of AI systems that are trustworthy and human-centric.

3. DPIA Methodology for Trustworthy AI Systems in SMES

The need for a methodology for carrying out a DPIA on AI systems emerges not only from the lack of concrete GDPR guidelines but mainly from the challenges faced by SMEs aiming to develop Trustworthy AI systems. As pointed out in Article 35 of the GDPR, although fundamental requirements are established, the regulatory text only provides general guidelines on how to carry out this assessment. This feature, coupled with the limited resources of SMEs and the complexity of AI systems, makes it necessary to develop a simplified methodology that can help these companies carry out DPIAs.

The methodology proposed here was developed from a systematic analysis of the main existing guidelines on the subject, notably those provided by the Article 29 Working Party and the Information Commissioner's Office (WP29, 2018; ICO, 2018, 2020). A distinctive aspect of this proposal is its ability to simultaneously harmonise the risk-based approach and the rights-based approach, offering a way for controllers to develop their own assessments, considering that there is no single or mandatory methodology determined by the control authorities.

The methodological structure is organised into seven sequential and interconnected steps: (i) identification of the need to carry out a DPIA; (ii) systematic description of processing operations; (iii) consideration of consultation with third parties; (iv) assessment of necessity and proportionality; (v) identification and assessment of risks; (vi) definition of mitigation measures; and (vii) documentation and assessment of the need for prior consultation. This framework has been developed to cover all the requirements of the GDPR, based on the ICO guidelines (2020) and WP29 (2018), with specific adaptations that reflect an interpretation geared towards the needs of SMEs in the development of Trustworthy AI systems.

The approach developed was specifically designed to help SMEs develop Trustworthy AI systems, balancing data protection needs with the practical limitations of these companies. The approach adopted seeks to simplify the impact assessment process without compromising its effectiveness, allowing SMEs to develop and implement AI systems that are both innovative and respectful of the fundamental rights of data subjects, thus strengthening their competitive position in the technology market.

3.1 Criteria to determine the need for DPIA

Determining the need for a DPIA is particularly important in the context of AI systems, where the automated processing of personal data is intrinsic to their operation. According to Article 35(1) of the GDPR, a DPIA becomes necessary when processing is likely to result in a high risk to the rights and freedoms of data subjects, a situation often present in AI systems due to their capacity for large-scale processing and analysis. To assess this need in the specific context of AI systems, two stages of analysis were established.

The first stage is based on the nine criteria developed by WP29, based on various references in the GDPR, including Article 35(3) itself, as well as Article 22 and Recitals (71), (75) and (91), a system that reflects the complexity inherent in assessing risks in the specific context of AI systems and the automated processing of personal data.

For AI systems, a DPIA is essential when data processing has at least two of the following characteristics (WP29, 2018):

(i) evaluation or classification operations through forecasting and profiling;

(ii) automated decisions with significant legal or similar effects;

(iii) observation, monitoring, or control of holders, or systematic control of areas accessible to the public;

(iv) processing sensitive or highly personal data;

(v) large-scale data processing;

(vi) combining data sets;

(vii) data from vulnerable data subjects, such as children and incapacitated persons, or from relationships where there is an imbalance of power, such as in the labour or consumer sphere;

(viii) use of new technological or organisational solutions; or

(ix) preventing holders from exercising rights or using services.

The second stage, based on Article 35(4) of the GDPR, refers to the mandatory consultation of the lists drawn up by the supervisory authorities of each Member State where the AI system will be implemented. This step is essential because certain types of processing, even if they do not present two or more characteristics of the WP29 criteria, may represent inadmissible risks from the perspective of the competent supervisory authority. Therefore, if data processing is included in the list published by the supervisory authority, it becomes mandatory to carry out the DPIA, regardless of the previous analysis.

If it is concluded that a DPIA is not necessary after analysing the two steps, the controller must document this decision with detailed reasons (ICO, 2018). This documentation must include the opinion of the DPO, when appointed, as required by Article 35(2) of the GDPR.

On the other hand, if there are still doubts about the qualification of the risk, it is recommended to carry out the DPIA as a preventive measure (WP29, 2018; ICO, 2018), thus adopting a cautious stance in protecting the rights and freedoms of data subjects processed by AI systems.

In the context of SMEs, in order to make this process more accessible and efficient, it is suggested the adoption of a structured approach that combines practical tools with collaborative support. Initially, SMEs can benefit from a simplified checklist that converts the nine criteria of WP29 into a practical checklist, complemented by concrete examples and use cases relevant to their sector. This tool can be integrated into a visual decision-making flow chart that guides company decisions through the evaluation process with "yes/no" decision points, reducing the complexity of the analysis. Furthermore, to create/strengthen a support ecosystem, it is recommended to establish sectoral experience sharing networks where SMEs can exchange practical knowledge about the implementation of DPIAs and discuss common challenges. This measure simplifies the process of determining the need for DPIAs, but also promotes a culture of collaborative compliance among SMEs, allowing them to optimise their limited resources while maintaining adherence to regulatory requirements.

3.2 Systematic mapping of operations

The systematic description of processing operations represents a key element of the DPIA, as established by Article 35(7)(a) of the GDPR. This description must: demonstrate the breadth of what is to be analysed by the DPIA and enable the controller to provide useful information about the automated processing. In this context, it is essential that the controller makes clear "how" and "why" it will use AI systems to process the data, providing detailed information on the nature, scope, context, and purposes of the processing.

The nature of the processing comprises the set of operations that the controller plans to carry out with the personal data. According to the ICO (2018), this includes specifying in detail how the data are collected, stored and used, who has access to these data and with which third parties it is shared (including processors), what retention period is established, what security measures are applied, and whether new technologies or new types of processing are implemented.

As for the scope of the processing, the controller must indicate aspects such as the specific nature of the personal data, the presence of special category data, the volume and variety of the data, the extent and frequency of the processing, its duration, the number of data subjects involved, and the geographical area covered. This information is fundamental for the subsequent assessment of the necessity and proportionality of processing.

The context of processing, in turn, covers internal and external factors that may affect the expectations of data subjects or have a negative impact on their rights. The ICO (2018) establishes that the controller must specify essential elements such as the source of the data, the level of control that individuals have over their information and their expectations regarding the processing. It is also necessary to identify whether there are children or other vulnerable people among the data subjects, and to verify compliance with approved codes of conduct, as provided for in Article 35(8) of the GDPR, or other certifications that the controller deems effective to ensure adequate data protection.

Finally, the mapping must address the purposes of the processing and the specificities of AI systems. According to the ICO (2018), the controller must clearly indicate what the intended result of the processing is, what the expected benefits are for both the controller and society, and give reasons for the legitimate interest in processing, where applicable. In the specific context of AI applications, the ICO (2020) stipulates that the phases in which automated processes may have an effect on the lives of data subjects must be recorded in the DPIA, including explanations of relevant variations or margins of error in system performance that may affect the fairness of the processing. It is equally important to document the degree of human involvement in the decision-making process and at what point it occurs, thus ensuring a comprehensive understanding of the functioning of the algorithmic solutions implemented.

3.3 Stakeholder consultation process

Article 35(9) of the GDPR states that the controller may request the opinion of data subjects or their representatives on aspects involved in the data processing. In practical terms, when this consultation takes place, the opinions gathered must be duly documented. However, if the controller believes that this consultation is not appropriate, they must give reasons for their decision and document this in the DPIA (WP29 2018, 17-18).

Furthermore, in cases where data are shared with processors, their participation or advice becomes essential, ensuring that the DPIA has all the necessary viewpoints for a comprehensive assessment.

Finally, the ICO (2018) recommends that during the DPIA there is specialised legal support and advice, as well as the participation of independent experts in areas such as IT, sociology, or ethics. This participation is important, as these experts will point out possible risks to holders from a multidisciplinary perspective. This diversity of views makes it possible to identify potential impacts that could go unnoticed under a one-dimensional analysis.

Recognising that hiring multiple experts can be financially unfeasible for SMEs, an effective alternative is to establish partnerships with civil society organisations working in the field of law and technology. These entities often have multidisciplinary researchers and experience in protecting the rights of data subjects, offering valuable perspectives on the possible social, cultural, and ethical impacts of data processing. This approach allows SMEs to carry out a comprehensive and meaningful DPIA, even with limited resources, while ensuring adequate consideration of the rights and interests of data subjects.

3.4 Evaluation of Necessity and Proportionality

Implementing AI systems for the automated processing of personal data requires a solid justification that goes beyond mere technological availability. As established by the ICO (2020), it is essential to prove the existence of a concrete problem to be solved and to demonstrate that AI represents a sensible solution to this issue. This careful approach is justified by the inherent risks of AI systems in the context of processing personal data, requiring a prior analysis to validate the real need for their implementation.

Once the initial need has been established, and following the guidelines of WP29 (2018), the DPIA must consider two complementary perspectives: (i) the necessity and proportionality of the processing, and (ii) the protection of the rights of data subjects.

Regarding the first perspective, the analysis of the necessity and proportionality of the processing of personal data requires the controller to examine the following criteria: whether the purposes are specific, explicit, and legitimate; whether the data are adequate, relevant, and limited to what is necessary; whether the processing respects the correct legal bases; whether the processing does not go beyond its purpose; and whether the accuracy and quality of the data are being guaranteed (WP29, 2018; ICO, 2018).

Specifically, with regard to the use of AI systems for automated processing of personal data, the ICO (2020) clarifies that the DPIA must provide reasons to justify this choice over less risky and intrusive alternatives, where they exist. This requirement becomes even stricter in cases where the processing is based on the public interest or legitimate interests, requiring an exceptionally robust justification. In such situations, it is essential to demonstrate not only the necessity of the automated processing, but also its proportionality in relation to the objectives pursued.

As for the second perspective, related to protecting the rights of data subjects, the implementation of AI systems requires an assessment of the reasonable expectations of data subjects regarding the processing of their personal data. As guided by ICO (2020), it is essential to analyse the reasonable expectation of data subjects to have their data processed by AI systems. This assessment must be conducted in accordance with the principle of transparency set out in Article 5(1)(a) of the GDPR, which underpins information duties and guides data processing in the context of AI.

To operationalise this protection, the development of AI systems requires a clear definition of operational procedures to guarantee the rights of data subjects. According to the WP29 (2018) guidelines, data controllers must establish: methodologies for providing information to individuals (articles 12, 13 and 14), management of access and portability requests (articles 15 and 20), execution of data rectification and erasure processes (articles 16, 17 and 19), and operationalisation of the rights to object and limit processing (articles 18 and 21).

Last but not least, the compliance of AI systems also requires the implementation of complementary protection measures. The ICO (2018) emphasises the need for safeguards for international data transfers. Furthermore, Article 22(3) of the GDPR establishes the obligation of processes that guarantee human intervention in automated decisions, ensuring that the data subject has the right to challenge and review these decisions.

3.5 Identification and assessment of risks

Identifying and assessing risks to the rights of data subjects (Article 35(7)(c) of the GDPR), when carried out in the context of AI systems, requires a comprehensive interpretation that goes beyond a singular view of the right to privacy and the protection of personal data. This analysis must consider all types of potential damage - physical, emotional, or material - resulting directly or indirectly from a personal information processing operation. This perspective is supported by the GDPR itself, which, according to Recital (04) and the WP29 guidelines (2017), establishes a direct relationship with the fundamental rights of the Charter, requiring an assessment that takes into account both direct and indirect impacts on these rights.

In the process of identifying specific risks, ICO (2018) establishes a comprehensive set of categories that should be considered in the context of data processing by AI applications. These categories range from aspects such as the ability to exercise rights and access services to more specific issues such as discrimination, loss of control over personal data, behavioural conditioning or manipulation, identity theft, financial and reputational damage, physical damage, and the possibility of reidentification of pseudonymized data. This assessment should consider not only the direct impacts on data protection, but also the indirect repercussions that the processing of personal data may have on other rights.

The methodology to assess these risks requires not only their identification, but also their appropriate quantification and categorisation according to severity levels. As the ICO (2018) points out, it is not necessary for damage to be unavoidable in order to be classified as a risk, whether high or not; the possibility of it occurring is solely sufficient. In this context, each controller is free to establish their own standards for quantifying and qualifying risks, allowing them to be adapted to the particularities of each AI system and its context of use.

3.6 Risk mitigation measures

The process of defining mitigating measures, as set out in Article 35(7)(d) of the GDPR, requires a structured approach, which begins with a detailed record of the sources of each risk identified in the previous stage of the DPIA. Only once the source of the risk is clearly understood, will the controller be able to seek appropriate measures to mitigate or eliminate it. This direct relationship between the source of the risk and the mitigating measure is fundamental, as the effectiveness of the actions implemented depends directly on their alignment with the specific nature of the cause of the risk identified.

Effective implementation of mitigation measures requires a multidisciplinary approach, considering that different sources of risk may require different technical or organisational measures. In this context, it is essential that the person responsible for managing these risks puts together a team of experts who can propose the appropriate measures, integrating professionals from technical and legal fields to ensure the effectiveness of the proposed solutions. This integration enables a comprehensive risk assessment and the development of more robust and complete mitigation strategies.

Considering the structural limitations of SMEs, the composition of a team to assess and propose mitigating measures must be scaled in a realistic and operationally viable way. A suitable methodological alternative is to establish strategic partnerships with sectoral or civil society organisations, business associations, or academic bodies that can meet the technical and legal needs without excessively burdening the organisational structure. This collaborative approach, in addition to being more affordable, enables a comprehensive risk assessment and the development of mitigation strategies appropriate for the reality of SMEs, harmonising regulatory requirements with the practical limitations of these organisations. However, in addition to the above-mentioned approach, the ICO (2018) presents a non-exhaustive set of measures that can be implemented, including reducing data collection, reducing the scope of processing, reducing retention periods, and implementing additional security measures. In addition, it recommends training those involved, using anonymisation or pseudonymization techniques, defining internal policies, and implementing systems to make it easier for data subjects to exercise their rights. The ICO (2020) also emphasises the importance of creating mechanisms that allow holders to opt out of automated decisions, thus strengthening the protection of fundamental rights.

3.7 Documentation and prior consultation process

Documenting the results of the DPIA requires the person responsible for handling it to follow a series of systematic procedures. As established by the ICO (2018), it is necessary to record the additional measures for mitigating or eliminating the risks identified, classifying them as "eliminated", "reduced", or "accepted". Additionally, any residual risks for which it has not been possible to define appropriate treatment measures must be identified.

The identified risks do not have to be completely eliminated, and some risks can be accepted after a proportionality analysis. According to ICO (2018), this analysis should consider the relationship between the risks identified, the expected benefits of processing, and the practical difficulties of mitigation. Proper documentation of this proportionality assessment is essential to justify the acceptance of any residual risks. However, the existence of a high residual risk requires prior consultation with the supervisory authority, as required by Article 36(1) of the GDPR.

The DPO plays an important role in this process and is required to issue an opinion on the DPIA when this professional is appointed, in accordance with Article 35(2) of the GDPR. If the opinion indicates that the assessment does not comply with the GDPR or is against the processing, the DPO may agree or disagree with the position, provided that he/she adequately substantiates his/her decision in the event of disagreement.

In addition to the opinion of the DPO, it is necessary to properly manage objections from data subjects consulted during the process. In this regard, the controller must provide reasoned justifications whenever it decides to

proceed with processing in the face of objections from data subjects, demonstrating that it has taken their opinions into account in the overall risk and compliance assessment.

4. Limitations of the Data Protection Regulatory Framework for DPIA in Trustworthy AI Systems

The analysis of DPIA in the specific context of this article reveals structural limitations in the current regulatory framework that may compromise its effectiveness as a risk governance instrument in Trustworthy AI systems.

The normative dimension of DPIA has its first structural limitation in the absence of a legal duty to publish the results. The WP29 (2017) expressly recommends the disclosure, although partial, of the conclusions obtained, but this measure remains a mere option for the person responsible for processing. This normative configuration compromises both the possibility of social control and the development of consolidated sectoral practices, especially given the potential impact of AI applications on fundamental rights.

The absence of specific criteria to assess bias and algorithmic discrimination is another structural limitation. Recital (75) of the GDPR expressly sets out the risks of discrimination, but there is a lack of objective parameters for assessing and measuring biases in AI-based technologies. This omission can result in methodologically inconsistent risk assessments.

The third limitation relates to the question of the explainability of automated decisions. Specialised doctrine has not yet reached a consensus on the extent of the right to explanation under the GDPR, particularly with regard to the possibility of requiring specific explanations for individual decisions (Wachter et al. 2016; Sartor 2020). This dogmatic vagueness could compromise the effectiveness of DPIA as an instrument of algorithmic transparency in algorithmic solutions.

Final Considerations

This paper investigated the viability of DPIA as a facilitating tool for SMEs to develop and implement Trustworthy AI systems. Through systematic documentary analysis of normative instruments, scientific articles, institutional guidelines from the European Union, and guidelines from data protection authorities, the convergence between the requirements of the GDPR and the ethical principles established for Trustworthy AI was examined.

The research was motivated by the significant challenges faced by SMEs in developing and implementing Trustworthy AI systems, including human and financial resource constraints, difficulties in understanding ethical issues and the complexity of the regulatory environment. The central question sought to understand how the DPIA could act as a facilitating instrument in this context, considering its already consolidated structure in the European legal system and its potential ability to integrate data protection requirements with ethical AI principles.

The results demonstrated the viability of the DPIA as a precursor methodological tool for implementing the requirements of trustworthy AI, based on the convergence of principles between the GDPR and European ethics guidelines. The research resulted in the development of a modular methodology that includes objective criteria for determining the need for an DPIA, systematised procedures for mapping processing operations, simplified mechanisms for consulting stakeholders, and frameworks for identifying and mitigating risks, adapted whenever possible to the operational particularities of SMEs.

Despite the progress made, the research identified significant structural limitations in the regulatory framework for the protection of personal data that deserve attention. The absence of a legal duty to publicize the results of the DPIA compromises social control and the development of consolidated sectoral practices. The lack of objective parameters in the GDPR for assessing bias and algorithmic discrimination can result in methodologically inconsistent analyses. In addition, the dogmatic vagueness regarding the extent of the right to explanation under the GDPR presents a challenge to the effective achievement of the ethical principle of explainability in Trustworthy AI systems. However, despite its limitations, this work offers significant contributions to both the theoretical and practical fields. In the academic field, it presents a systematic analysis of the convergence between data protection and AI ethical principles, filling an important gap in the legal literature. From a practical perspective, it provides SMEs with an accessible and structured methodological framework for developing Trustworthy AI systems, taking into account their

operational limitations and available resources. The proposed methodology represents a significant advance in the operationalization of ethical and regulatory requirements in the specific context of SMEs.

As a natural outgrowth of this research, an in-depth analysis of how the DPIA can serve as a preparatory basis for SMEs to comply with the AI Act and its requirements for developing and implementing AI systems is suggested for future work, especially considering the specific impact assessments required by the new regulation for high-risk systems. The knowledge acquired by SMEs while conducting DPIAs on AI systems could significantly facilitate their future compliance with the AI Act, thus establishing a continuum of regulatory compliance.

Given all that has been presented, this article has shown that DPIA can effectively act as a facilitating instrument for SMEs to develop Trustworthy AI systems, provided that it is properly adapted to their operational particularities. The proposed methodology offers a structured path for these companies to implement technical and legal safeguards without compromising their innovation capacity. The knowledge acquired by SMEs while conducting DPIA on AI systems could significantly facilitate their future compliance with the AI Act, highlighting the growing importance of this instrument in the European regulatory landscape for emerging technologies.

Bibliographical References

Bo Li, Peng Qi, Bo Liu, Shuai Di, Jingen Liu, Jiquan Pei, Jinfeng Yi, and Bowen Zhou. 2023. Trustworthy AI: From Principles to Practices. ACM Comput. Surv. 55, 9, Article 177 (September 2023), 46 pages. https://doi.org/10.1145/3555803

Cordeiro, A. Barreto Menezes. Data Protection Law. Coimbra: Almedina, 2020.

Cortiz, Diogo. "Can Design help build humanistic Artificial Intelligence?" Proceedings of the 17th ERGODESIGN - International Congress on Ergonomics and Usability of Human-Technology Interfaces: Product, Information, Built Environment and Transportation (2019).

Elias, G., Carayannis, Roman, Dumitrescu, Tommy, Falkowski, Nikos, -, Rigert, Zota (2023). Empowering smes-"harnessing the potential of gen ai for resilience and competitiveness". IEEE Transactions on Engineering Management, 1-22. doi: 10.1109/tem.2024.3456820

Evas, Tatjana. "European Framework on Ethical Aspects of Artificial Intelligence, Robotics and Related Technologies." European Parliament Research Service (2019).

Floridi, L., J. Cowls, M. Beltrametti, R. Chatila, P. Chazerand, V. Dignum, C. Luetge, et al. "AI4People: An Ethical Framework for a Good AI Society: Opportunities, Risks, Principles, and Recommendations." Minds and Machines 28, no. 4 (2018): 689-707.

Hijmans, Hielke, and Charles D. Raab. "Ethical Dimensions of the GDPR." In Commentary on the General Data Protection Regulation, edited by Mark Cole and Franziska Boehm. Edward Elgar Publishing, 2018.

Keeley, Alexandra, Crockett, Edwin, Colyer, Luciano, Gerber, Annabel, Latham (2023). Building Trustworthy AI Solutions: A Case for Practical Solutions for Small Businesses. IEEE transactions on artificial intelligence, 4:778-791. doi: 10.1109/TAI.2021.3137091

Kloza et al, 'Data Protection Impact Assessments in the European Union: Complementing the New Legal Framework towards a More Robust Protection of Individuals';

Kuner, Christopher, Lee A. Bygrave, Christopher Docksey, and Laura Drechsler. The EU General Data Protection Regulation (GDPR): A Commentary. Oxford: Oxford University Press, 2020.

Leon, Oldemeyer, Andreas, Jede, Frank, Teuteberg (2024). Investigation of artificial intelligence in SMEs: a systematic review of the state of the art and the main implementation challenges. Management review quarterly, doi: 10.1007/s11301-024-00405-4

Malgieri, Gianclaudio, and Margot E. Kaminski. "Algorithmic Impact Assessments under the GDPR: Producing Multi-layered Explanations." International Data Privacy Law (2019).

Michael Veale, Reuben Binns, and Jef Ausloos, 'When Data Protection by Design and Data Subject Rights Clash', International Data Privacy Law 8, no. 2 (1 May 2018), https://doi.org/10.1093/idpl/ipy002

Nineta, Polemi, Isabel, Praça, Kitty, Kioskli, Adrien, Bécue (2024). Challenges and efforts in managing AI trustworthiness risks: a state of knowledge. Frontiers in big data, doi: 10.3389/fdata.2024.1381163

Samuel, Omokhafe, Yusuf., Remilekun, Lilian, Durodola., Godbless, Ocran., Justina, Eweala, Abubakar., Amarachi, Zita, Echere., Adedamola, Hadassah, Paul-Adeleye. (2024). Challenges and opportunities in AI and digital transformation for SMEs: A cross-continental perspective. World Journal Of Advanced Research and Reviews, 23(3):668-678. doi: 10.30574/wjarr.2024.23.3.2511

Sartor, Giovanni. 2020. "The Impact of the General Data Protection Regulation (GDPR) on Artificial Intelligence." European Parliamentary Research Service: 54-55.

Toluwalase, Vanessa, Iyelolu., Edith, Ebele, Agu., Courage, Idemudia., Tochukwu, Ignatius, Ijomah. (2024). Driving SME innovation with AI solutions: overcoming adoption barriers and future growth opportunities. International Journal of Science and Technology Research Archive, doi: 10.53771/ijstra.2024.7.1.0055

Wachter, Sandra, Brent Mittelstadt, and Luciano Floridi. 2016. "Why a Right to Explanation of Automated Decision-Making Does Not Exist in the General Data Protection Regulation." International Data Privacy Law 7: 76-99.

Normative Documents

European Union. Charter of Fundamental Rights of the European Union. Official Journal of the European Union, C 326/391, 26.10.2012.

European Union. Consolidated version of the Treaty on European Union. Official Journal of the European Union, C 326/13, 26.10.2012.

European Union. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data. Official Journal of the European Union, L 119/1, 4.5.2016.

Institutional Documents

Article 29 Data Protection Working Party. Opinion 3/2010 on the principle of accountability. European Commission, Brussels, 2010

Article 29 Data Protection Working Party. "Guidelines on Data Protection Impact Assessment (DPIA)." European Commission, Brussels, April 2017.

European Commission. Building Trust in Human-Centric Artificial Intelligence. COM(2019) 168 final. Brussels, 2019.

High-Level Expert Group on AI (AI HLEG). "Ethics Guidelines for Trustworthy AI." European Commission, Brussels, 2019.

Information Commissioner's Office. "Guidance on AI and Data Protection." Version 0.0.22. London: ICO, July 2020.

Information Commissioner's Office. "Guidelines on Data Protection Impact Assessments." Version 1.0.124. London: ICO, May 2018.